Julio Coronado-Toscano (015844322)
Alfredo De La Torre(015634697)
CMPE 132-Information Security
11/24/24
Project- Implementation version 2

Part 1:

Web Layout:

- Home Page:
  - The main navigation for the website
  - Users will be able to register for an account through the page, access the collection of books (but needs to be signed into an account to do that).
- Admin Section
  - Needs to login to verify and authenticate they are them
  - Admin will be able to see all the users information
  - Can delete or approve users that registered
- User Section
  - Needs to login to verify and authenticate they are them
  - Can login into their account to browse books and if allowed to do book management and rent out books
- Authentication process
  - Authenticating users through the information they signed up with. We will have them login with their password and email they registered with
  - The password they signed up with is hashed and stored away, and when d=the user is trying to login as that specific person the system will compare the two passwords.

Provisioning for Users:

- User signup:
  - User provides information about to make an account
  - The password is then hashed using Bcrypt then all the information is stored into their database
  - To have access to the account the admin needs to approve the users
- Admin Approval Process
  - Admin has to login and go to the database to view all processed and being processed accounts.

    - From there the admin can deny or approve the users
    - Once the users are approved they are stored into the database and their information is securely stored
    - For users that are registering for an account their status is set at a 0, meaning it has not been approved yet. However, when the user is approved the status is set to a 1.
- User Authorization:
    - After being approved the users verify their login credentials by trying to login, and they gain access to the user dashboard

De-Provisioning for Users:

- When deleting users the admin will press the delete button next to their name on the database and their information will be wiped from the database.

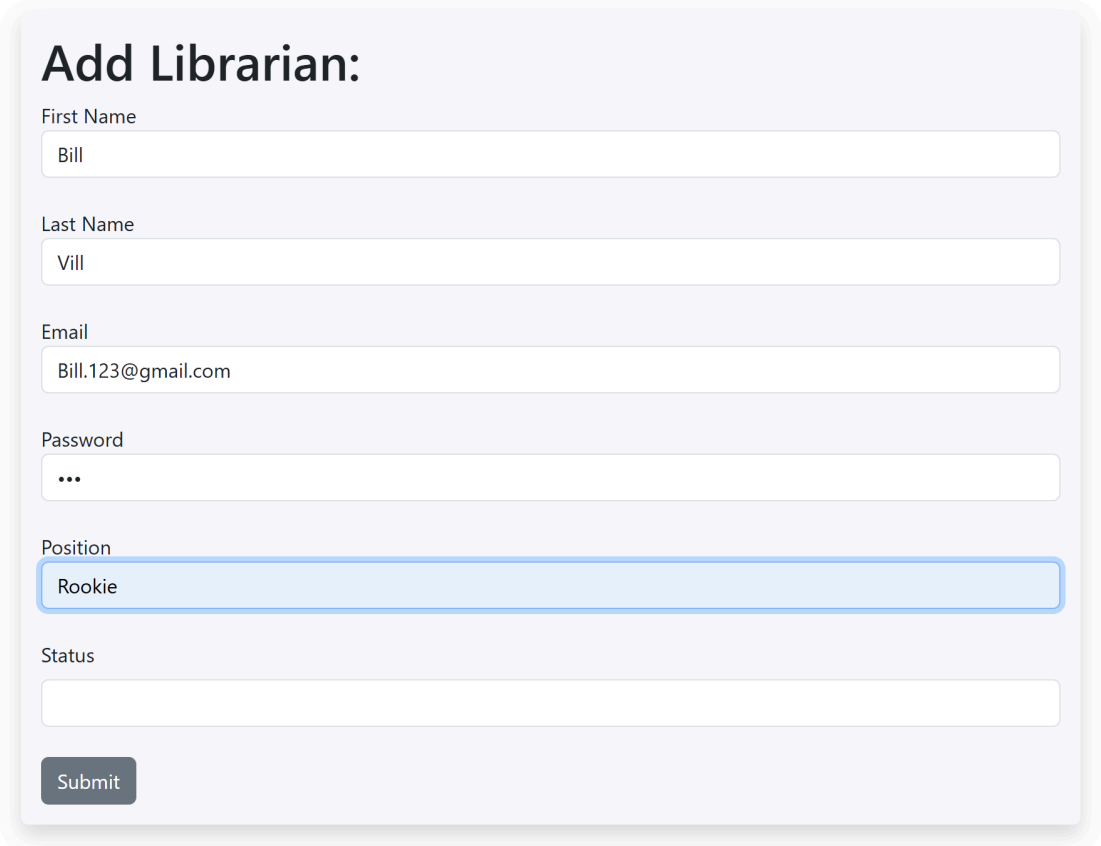
Hashing Mechanism:

- Bcrypt hashing:
    - It is a hashing function that takes in plaintext and hashes that plaintext. It uses the command bcrypt.generate_password_hash()
    - It first generates a random salt that is added to the plaintext password
    - Then it hashes the combination of the plaintext and salt by using it's Bcrypt algorithm
    - During the authorization process we use a command called bcrypt.check_password_hash() and that compares the hashes by extracting the salt from the salt from the stored hash in the database. Then rehashes the password given during the login process with the salt extracted and compares the two hashes
- Criteria for using Bcrypt
    - Its main task is to hash. It was made for hashing
    - Helps prevents attacks of rainbow table attacking, and does that by implementing salt
    - Brute-force-attacks don't work against it too
    - It is not difficult to incorporate in the project. Mainly uses two lines of code:
        - bcrypt.generate_password_hash()
        - check_password_hash()
    - Has an implementation called cost factor and uses
- Strengths and weaknesses:
    - Strengths:

        - It is protected from multiple types of attacks
            - brute force attacks
            - Rainbow table attacks
            - Collision attacks
        - It is a reliable way of hashing confidential information, and trusted by many users
    - Weaknesses:
        - It's only used for password hashing, and it is a bit outdated compared to the "modern day" algorithms
        - Its performance is not as fast as other algorithms like Argon2.

Part 2:

Librarian



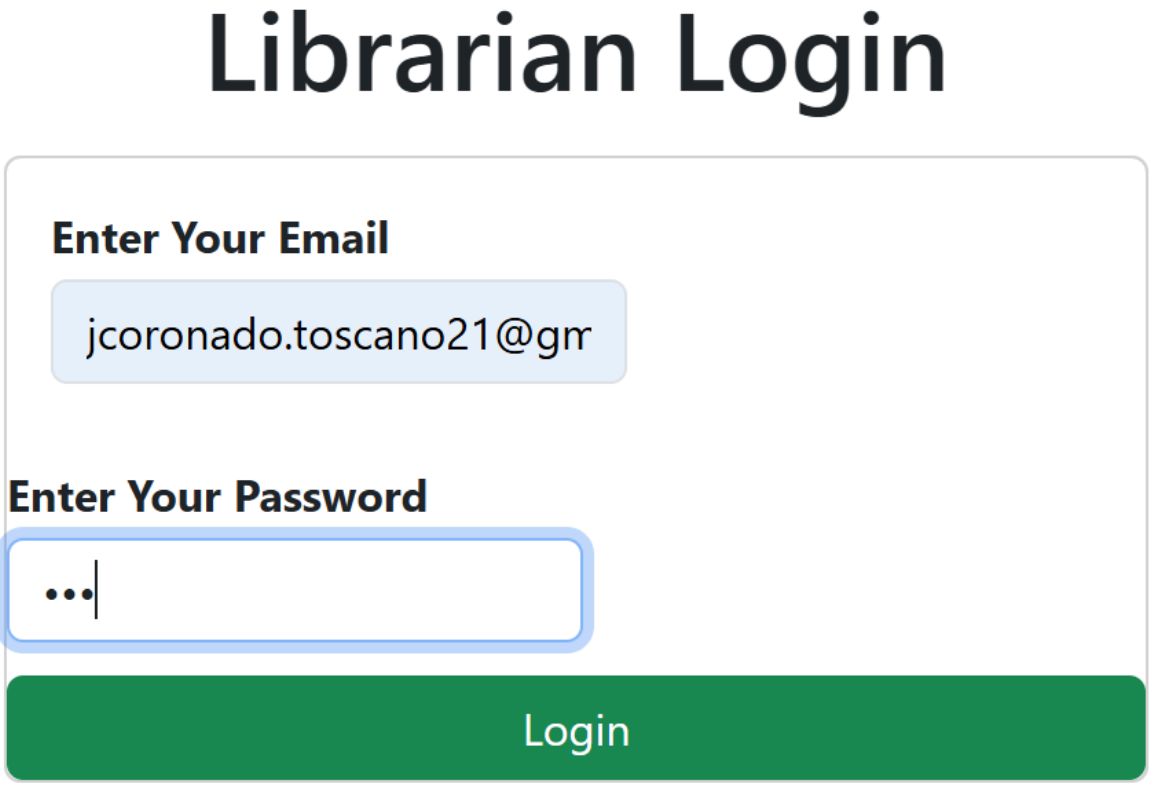
Id	First Name	Last Name		
1	Julio C	Coronado-Toscano	Edit	Delete

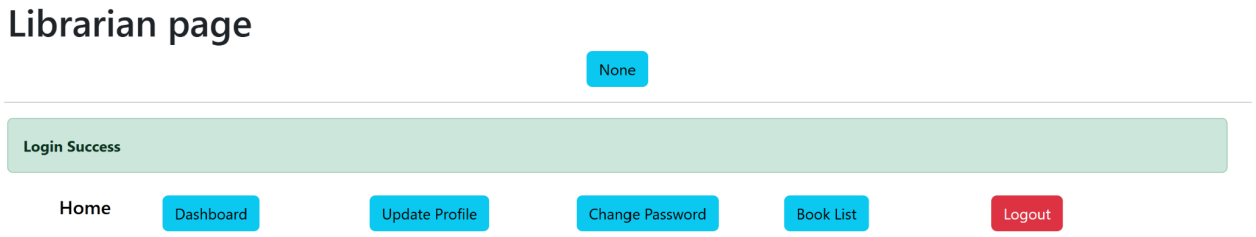
To add a Librarian the admins can do this and only they can update or delete them.



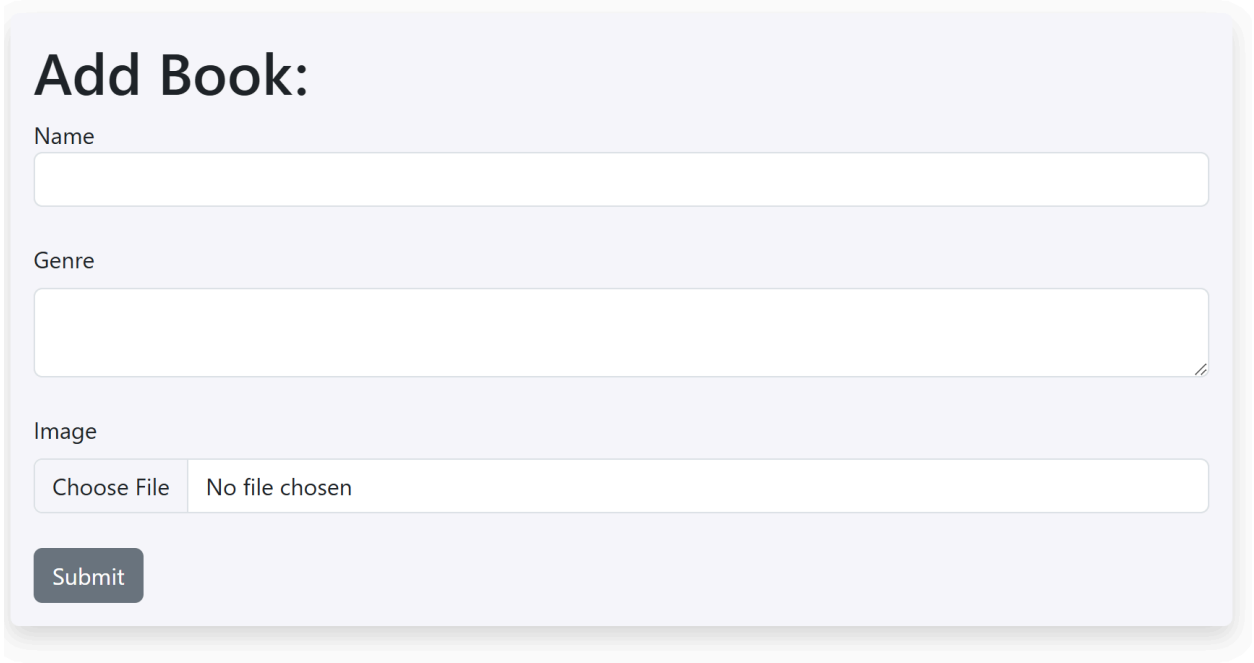
Id	First Name	Last Name		
1	Julio C	Coronado-Toscano	Edit	Delete
2	Bill	Vill	Edit	Delete

Once added they will show up in the table below. The admin can edit or delete the Librarian using the buttons next to their name.





The dashboard for the librarian

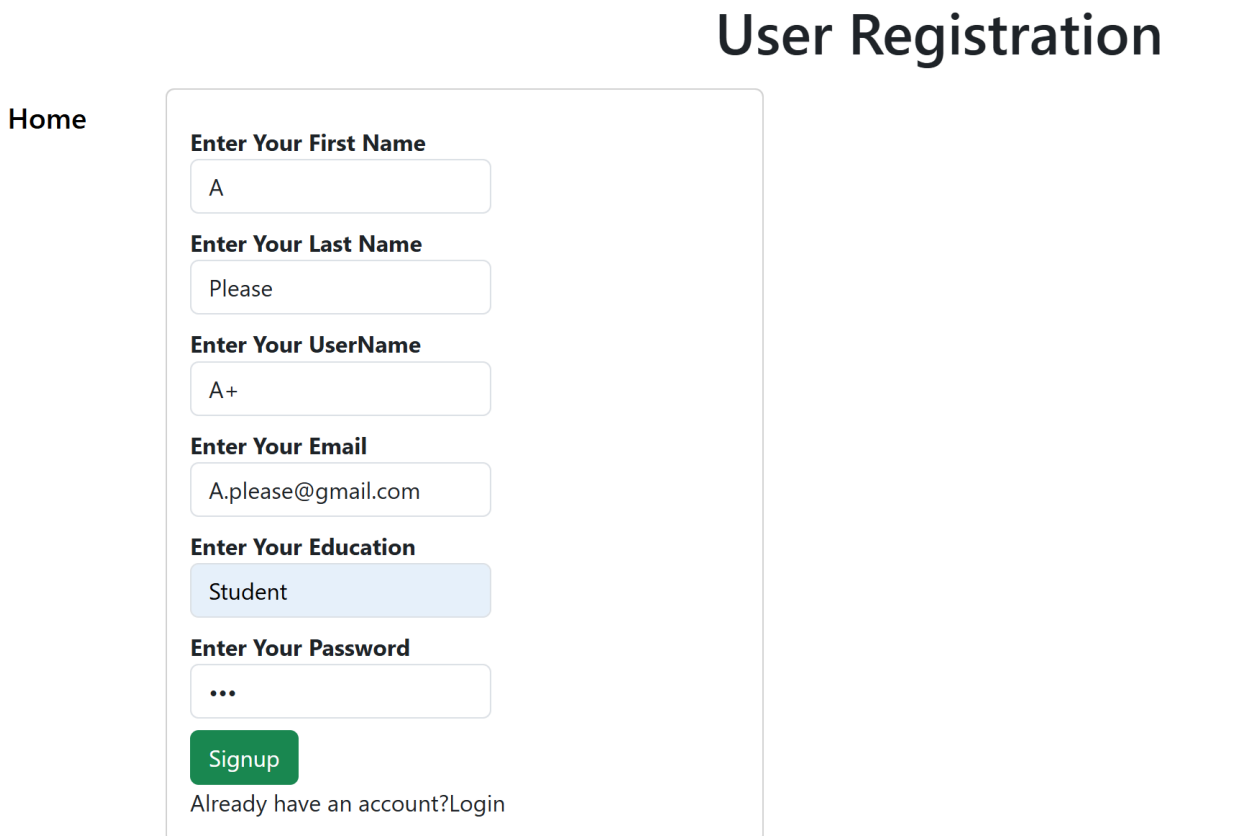


Id	Name	Genre		
1	The Secret Life of Sunflowers	Historical Fiction, Romance	Edit	Delete
2	Books to Die for	Mystery	Edit	Delete

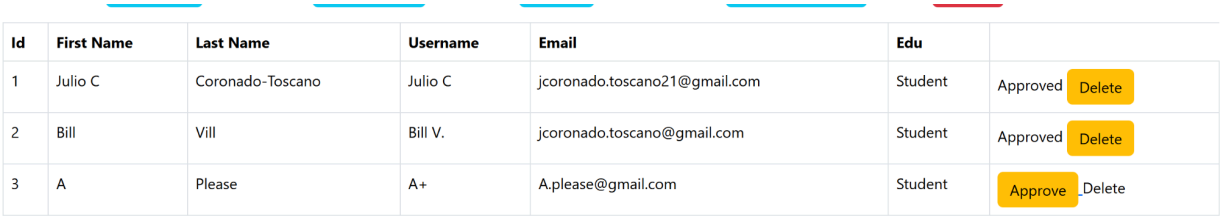
Librarians can delete and add books to the sight. Using buttons similar to that of the admin adding and removing Librarians.

User Registration / Login

regular user page

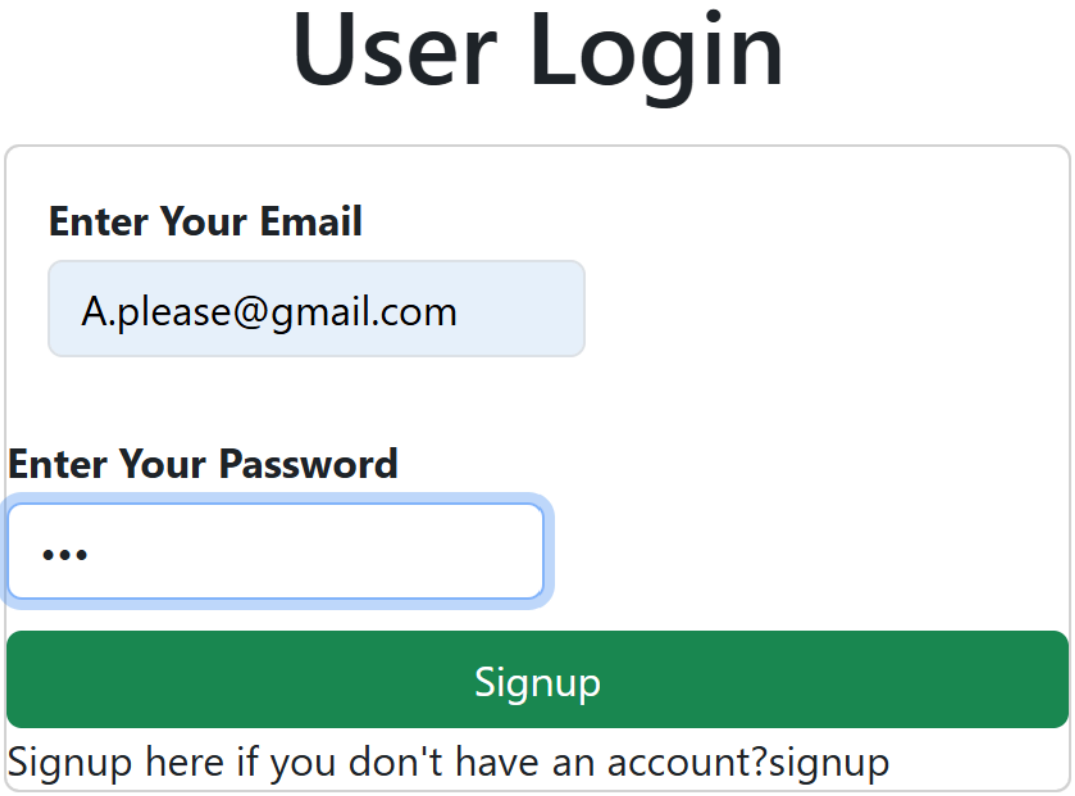


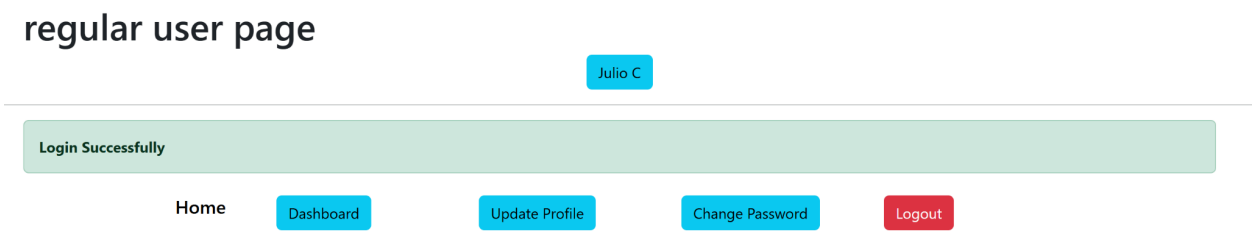
Once the registration goes through the admin has to approved the account.



Id	First Name	Last Name	Username	Email	Edu	
1	Julio C	Coronado-Toscano	Julio C	jcoronado.toscano21@gmail.com	Student	Approved Delete
2	Bill	Vill	Bill V.	jcoronado.toscano@gmail.com	Student	Approved Delete
3	A	Please	A+	A.please@gmail.com	Student	Approve Delete

From the admin page under all users, they can choose whether to approve the account or delete it.





The user login takes in the email that they used to sign up and then the password that they used. Once logged in they can view the user dashboard. Where they can change their password or profile. The name under the regular user page text is related to the username of the user. This will persist through any page to which they have access otherwise they need to sign into an account that has that access. This is the same process for Users and admins.

Here are some photos for the database to show that each input is different from the other and they correlate correctly to each user.

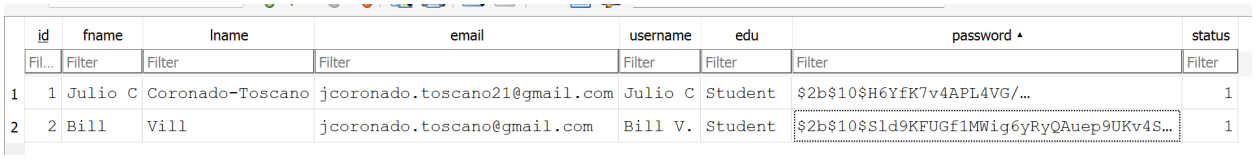
Admin Table

1	hilal123	$2b$10$El6UlEN0XrbdpnRmm2KkpO99jXKrQ…
2	hilal123	$2b$10$goJPN4iT2EpBcq6Spmc8PuxydyH2p…
3	hilal123	$2b$10$Rs17sx3Wo/…
4	hilal123	$2b$10$cjzJAWdrCfsJqeFI6x/…

Username Password

This is a small snippet of the Admin table in the database we put in this user using the same username and password when sighing up hilal123 with the password of hilal123 which when hashed gave us the different hashes for each user.

User table



	id	fname	lname	email	username	edu	password	status
	Fil…	Filter	Filter	Filter	Filter	Filter	Filter	Filter
1	1	Julio C	Coronado-Toscano	jcoronado.toscano21@gmail.com	Julio C	Student	$2b$10$H6YfK7v4APL4VG/…	1
2	2	Bill	Vill	jcoronado.toscano@gmail.com	Bill V.	Student	$2b$10$Sld9KFUGf1MWig6yRyQAuep9UKv4S…	1

Here is another example but for the user table where they have the same password but they are hashed differently

The passwords are different because of the flask function of b-crypt which does the hashing and also salts the password. In turn, making each one unique.

Part 3:

What was the most intellectually compelling part of the Project?

The part that was the most compelling was setting up the database so that it could be read and written from the forms on the webpage. This was because it was a topic that would relate to other classes that we needed to take and would give us an idea of how they work. Also the idea of creating secure websites that can take in information from users.

How might you apply what you learned in this project in the Future?

In the short term, this can be applied to future projects that we have in other classes that are in the same vein as this. Allowing us to get a better understanding and be able to create better and more secure websites with each attempt that we take

In the long term, it showed us how to work with other contributors while using GitHub which we may use for projects in the future when working with others in an office environment. It also allowed us to continue to build skills that will be crucial to future projects as we join the workforce.

What did you learn from this project?

We learned how to create a website that had different roles and had to be a certain role to access certain information on the website. We also learned how to make a form on a website that could take information and put it into a database for reference later. We also learned how to encrypt imputed passwords for each user using a flask addon called b_crypt which did the hashing before it was put into the database. Also, we learned how to use GitHub in a way that allowed us to work on the project at the same time without having to worry about getting in each other's way and messing with each other's changes to the code.

Which part of this project was the most challenging or difficult?

The most difficult part was taking information from the site and putting it into the database correctly. This was an issue for a while because of the way that we had made the functions for the page. This led to a lot of trial and error of what worked and what didn't and then building more on what did tell it fully worked. Another issue was making sure that every page led to the desired page and that there were no errors in this. This was a bigger problem when it came to removing or updating this in the database. Often times it would do the desired processor but would end up giving a No Url found error. This was later resolved to display the correct page. This type of error was prevalent while we were setting up the page. Another issue we had was setting up a GitHub so that we could share the code in a way that we could both work on it without having to zip the project and send it to each other.

Sources:

- Secure Hashing using BCrypt for Cryptographic Applications | IEEE Conference Publication | IEEE Xplore
- (5069) Flask Tutorial #1 - How to Make Websites with Python - YouTube
- Navbar · Bootstrap
- Quickstart — Flask Documentation (3.0.x)
- (5627) Role Based Access Control - YouTube
- Flask - Role Based Access Control - GeeksforGeeks
- Flask Basics- Playlist on how to set up a Flask WEbsite
- Bootstraps for many different styleistic changes to the website